PhishGuard

AI Email Phishing Detector with Explainable Verdicts

FutureTech HackFest 2026 · Applied AI × Cybersecurity · Chiara De Venuto

offline-first | privacy-preserving | 98.75% CV accuracy

01 The Problem

- Phishing is the #1 way attacks get started, with millions of new phishing sites appearing every quarter.
- The question that matters is not "is this link blacklisted?" but **"is this email trustworthy?"**, and it needs an answer before you click.
- Most detectors are **black boxes**: they return a verdict with no reasons, so you never learn how to protect yourself.
- Most detectors also **depend on the cloud**, which means your email content is sent to a server somewhere else.

02 The Solution

You paste an email into PhishGuard and get:

- **A risk score from 0 to 100** and a clear verdict: SAFE, SUSPICIOUS or PHISHING
- **Evidence you can read**: the exact signals and words that raised the score, so you understand the *why*
- **100% offline**: no API keys, no cloud, no data ever leaving your machine
- A simple web interface, plus a JSON API for developers

03 How It Works

```
email text ──► TF-IDF (1-2 grams, 1677 features) ─┐
               ├──────────────────────────────────┼──► hstack ─► Logistic Regr
               └─► 15 heuristic features (scaled) ─┘                  │
                                          verdict + evidence ◄────────┘
```

- **ML layer**: picks up subtle patterns in the text that are hard to describe by hand.
- **Heuristic layer**: encodes expert knowledge such as typosquatting domains, raw-IP URLs, Reply-To mismatches, urgency keywords and attachment hints.
- **Interpretable by design**: logistic regression coefficients can be read directly, and the interface shows them to you.

04 Data & Methodology

- **720 emails**, balanced between 360 phishing and 360 legitimate, generated deterministically (seed 42) from documented phishing patterns. The generator lives in the repository, so the dataset is **fully reproducible**.
- **Hard examples on purpose**: legitimate emails that mention words like "verify your email" or "password changed", plus low-intensity phishing that stays calm.
- Features: TF-IDF (1-2 grams) plus **15 interpretable heuristics**.
- Model: **Logistic Regression** with balanced classes. A strong baseline that is fast and explainable.
- Evaluation: stratified holdout, **5-fold cross-validation** and an ablation study.

05 Results

Metric	Holdout (20%)	5-fold CV
Accuracy	**98.61%**	**98.75%**
Precision	**100%**	**100%**
Recall	**97.22%**	**97.50%**
F1	**98.59%**	**98.73%**

Holdout confusion matrix: [[72, 0], [2, 70]]. Zero false positives, 2 false negatives.

06 Demo Flow

1. Paste any email, suspicious or normal
2. Get the **score bar** and verdict badge
3. Read the **evidence**: active features and top indicators
4. Act on the advice, before clicking anything

100 PHISHING → 5 SAFE

Real output from the running app (see demo video).

07 Innovation

- **Explainability is the feature**: using PhishGuard teaches you what to look for, and security awareness is the first line of defense.
- **Offline-first and private**: email content never leaves the device, which is rare among modern detectors.
- **Reproducible data**: the whole corpus is generated by auditable, committed code.
- **Dual-layer defense**: machine learning plus expert heuristics, and both layers are visible to the user.

08 Limits & Roadmap

- The dataset is synthetic, so validation on real-world mail (Enron corpora and live phishing feeds) is the immediate next step.
- Text indicators are single tokens today; natural-language explanations are the follow-up.
- Logistic regression is a strong baseline, and a fine-tuned transformer is a possible upgrade if you accept the trade-off in size and interpretability.

ROADMAP

- Browser extension and email-client plugin
- Threat-intel blacklist as a third layer
- Better explanations for the SUSPICIOUS band

09 Technology Stack

Python 3.12 · Flask 3.1 · scikit-learn 1.9 · TF-IDF · Logistic Regression · joblib · unittest

OPEN-SOURCE ONLY · NO EXTERNAL SERVICES · MIT

GitHub: public repository with full code, dataset generator, tests and docs.

10 AI Use Disclosure

Developed **with the assistance of generative AI tools** (scaffolding, code generation support, debugging, documentation drafting). All code was reviewed, executed and tested locally; every metric comes from running the code.

Framework:

- **Regulation (EU) 2024/1689 (EU AI Act), Art. 50** (transparency, applicable since 2 Aug 2026). Voluntarily applied: research/educational open-source project.
- **Italian Law No. 132/2025, Art. 13** (clear, simple and exhaustive information on AI use).
- **EU Code of Practice on Transparency of AI-Generated Content** (final, 10 June 2026).

Training data: fully synthetic, self-generated, no third-party works. No personal data collected or transmitted (GDPR-aligned).

Thank You

PhishGuard. Know why. Click safely.

FutureTech HackFest 2026 · Chiara De Venuto